② L'attaquant force la machine cible a se connecter à son serveur et à s'y authentifier. Cela peux se faire de differente façon, avec un fichier .url ou .lnk piégé de posé sur un partage, une injection HTML ou XSS sur une application web internes. Un appel MSRPC spécifique (comme la célèbre faille PetitPotam ou PrinterBug).

③ Une fois le hash récuperer on peux tenter de le casser et/ou faire une attaque par relay SMB. (NB, les hashages capturer par responder sont sauvgardés dans /usr/share/responder/logs/). L'attaque relay SMB fonctionne de manié assez simple, on va capter les challenges reponse de la victim et les rejouer entant real vers une autre machine et ainsi obtenir une session authentifié avec les droits d la victime.

1- On règle SMB sur OFF dans la config de responder pour l'empêcher de s'attribuer le port 445

```
Agentpathogene@parrot ~$ sudo nano /etc/Responder/Responder.conf
```

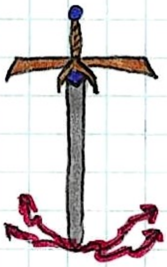
2- On utilise ntlmrelayx pour récupérer "la connexion" de la cible et la renvoyée en direct sur le serveur SMB victim, l'option --no-http-server sert à désactiver le faux server web que l'outil lance par default pour intercepter les connexions htt

⚠ on doit laisser responder tourner car il oriente le trafic de la victime vers notre machine attaquante (ou l'attend ntlmrelayx) (Ex si un user tape un mauvais nom de sharefolder la machine envoi une requête multicast à tout les appareils du réseaux, responder capte cette requete repond "c'est moi qui est sharefolder mal écri à tel IP (notre machine d'attaque) forcant ainsi la victim à se connecter à notre machine d'attaque)

- Par default si on précise pas de commande (-c) l'outil extrait la DB_SAM

```
Agentpathogene@parrot ~$ impacket-ntlmrelayx --no-http-server -smb2support -t ipouonredirigelaconnexion
```

On peux etablir un revshell en rajoutant -c 'powershell -e blocrevshellb64 a la fin de notre commande bien sur n'oublions pas le listenner.
Comme vulnérabilité récente on a SMBGhost alias CVE-2020-0796 permettant une RCE non authentifié c'est une vulnérabilité extremement dur a exploiter...



Attaquer les Base de Données SQL :

MySQL et MSSQL sont des systems de gestion de base de données relationnelles qui stockent les données en tables colonnes et lignes. Utilisant le langage SQL pour utiliser et maintenir les bases de données. Ces services stockent des données sensibles et sont souvent configurés avec des utilisateurs privilégiés.
MSSQL et MYSQL prennent en charges differentes methodes d'authentification; (l'auth Windows, ces services sont étroitement integré à Windows et AD ou par SQL Server via username et mot de passe).

Avant de passer aux attaque il est nécessaire de comprendre ces technologies et d'avoir la syntaxe de base de l'interaction...

- MySQL - Connexion au Serveur

```
                                                          mon domain
~$ mysql -u username -pPassword -h targetIP -windows-auth
```

- MSSQL - Connexion au Serveur

```
                                                         largeur affichage table
~$ sqlcmd -S NOMDUSRV -U lolsec -P "lol123!" -y 30 -Y30
~$ sqsh -S ipserver -U username -P 'Password' -h ⇐ affiche propre
~$ impacket-mssqlclient -p dbport username@ipserver
```